



Security Auditing

Nuno Seixas & Paulo Simões

School year 2025/2026

Master in Informatics Security (MSI) / Master in Informatics Engineering (MEI)

Informatics Engineering Department

University of Coimbra



Who Are we?

- Paulo Simões
 - Email: *psimoes@dei.uc.pt*
 - Office: D3.16
 - Office hours:
 - Wednesday, 15h-18h
(please schedule in advance)
 - or at any other time; just e-mail me to schedule another time
- Nuno Seixas
 - Email: *naseixas@dei.uc.pt*
 - Office: D3.5
 - Office hours:
 - Thursday, 14h-18h
(please schedule it by Slack first)
 - or at any other time; just send me a message in Slack



Summary

- Objectives
- Course topics
- Course outcomes
- Course organization
- Effort planning and assessment
- Real world examples and case studies
- Practical assignments



Course Objectives (1)

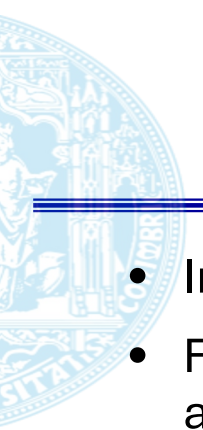
- This course aims to integrate the knowledge obtained in the various disciplines in the **security auditing** context
- It also aims to develop skills in cyber security compliance assessment and management, security risk analysis, and security risk assessment and management at the organizational and system levels.
- This course also aims to develop competences in the design and operation of platforms for collection and analysis of forensic data in informatic systems, both for post-incident analysis and for support of audit and policy monitoring activities.
- The skills will be consolidated through real-world examples, case studies, and practical assignments that use the methodologies, procedures, standards, and tools for conducting security audits in organizations.



Course Objectives (2)

Additionally, the course aims to develop the following secondary competencies:

- Application of theoretical knowledge on security assessment and management, competencies in analysis and synthesis, critical reasoning, and self-learning.
- Problem-solving, oral and written communication, interpersonal relations, and teamwork.



Course Topics

- Introduction to ICT security auditing
- Frameworks, standards, procedures and controls for ICT security compliance and auditing
- Tools for of ICT security auditing and certification
- Ethics and deontology in ICT auditing
- Fundamental principles of forensics analysis
- Platforms for collection and preliminary treatment of forensic data
- Post-mortem incident analysis
- Application of forensics platforms to auditing processes and to the enforcement of corporate and cybersecurity policies
- Real world examples and cases studies
- Practical assignments of ICT auditing and forensics analysis



Course Outcomes

- This curricular unit aims to acquire knowledge and skills in the security auditing and IT forensics areas.
- In this sense, techniques, standards, procedures and tools to carry out computer security auditing in organizations will be addressed.
- Design principles and best practices for collecting and handling IT forensics data will also be addressed.
- The knowledge gained will be implemented by the students in practical assignment.



Classes Organization

- Theoretical classes
 - Presentations by the teacher
 - Presentations by invited experts about real world examples
- Practical classes
 - Presentations by the students
 - Support to practical assignments and case studies
 - Discussion about case studies and practical assignments
 - Can be replaced by online interactions



Effort Planning

- Assumptions
 - 1st cycle in Informatics Engineering (or equivalent)
- Contact hours
 - Lectures: 28 hours
 - Support to assignments: 28 hours
- Other (office, email, ...): 8 hours
- Hours of individual work: 98 hours
- Total effort: 162 hours = 6 ECTS



Assessment

- **Case Study** – The need for a Forensics Infrastructure
 - 10% of the final grade
- **Practical Assignment 1** – Security Audit Simulation
 - **Milestone 1:** 10% of the final grade
 - **Milestone 2:** 30% of the final grade
- **Practical Assignment 2** – Forensics in Practice
 - 20% of the final grade
- **Exam**
 - 30% of the final grade
 - Open book (can use your laptop)
 - No minimum grade



Case Study

- **Case Study – The need for Forensics Readiness**

- **10%** of the final grade, without minimums
- 4-Student Groups: Estimated for up to 12 hours of **individual** work each
- To be discussed in Practical Class
- Submission date: **March 1st 23:59**
- Discussion date: **March 2nd** (Practical Class)
- Assessment criteria:
 - Writing correctness and objectiveness (10%)
 - Characterization of state-of-the-art (30%)
 - Critical Analysis (50%)
 - Participation in the discussion (10%)



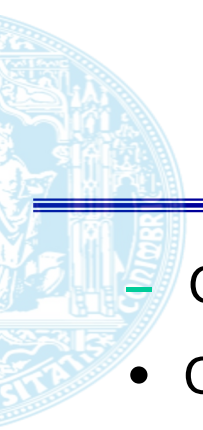
Practical Assignment 1 – Milestone 1

- Group work of 4 students, estimated for up to 20 hours each
- Objectives
 - *Plan and execute a security audit aligned with ISO27001*
- Submission:
 - **Audit Plan and initial analysis**
 - Deadline: **March 15th (23:59)**
- Weight: 10%



Practical Assignment 1 – Milestone 2

- Group work of 4 students, estimated for up to 20 hours each
- Objectives
 - *Present the findings from the security audit*
- Submission:
 - **Audit report**
 - Deadline: **April 19th (23:59)**
- Discussion:
 - Presentation: **10 minutes on April 20th**
 - Theoretical and Practical classes
- Weight: 30%



Practical Assignment 2

- Group work of 4 students, estimated for up to 20 hours each
- Objectives
 - *To design and deploy a Forensics infrastructure in a small IT organization.*
- Submission:
 - **Structured report + process artifacts (e.g. configuration files)**
 - Deadline: **May 10th (23:59)**
- Discussion:
 - Presentation: **10 minutes on May 11th and 18th**
 - Practical classes
- Weight: **20%**



Bibliography (1)

- Martin Weiss & Michael Solomon, **Auditing IT Infrastructures for Compliance**, Second Edition, Jones & Bartlett Learning, ISBN-13: 9781284090703, 2016.
- Edward Humphreys, **Implementing the ISO/IEC 27001 ISMS Standard**, Second Edition, Artech House, 2016.
- IT Governance Privacy Team, **EU General Data Protection Regulation (GDPR), An implementation and compliance guide**, ITGP, 2016.
- G. Johansen, **Digital Forensics and Incident Response: Incident response tools and techniques for effective cyber threat response** (3rd edition) 2022.
- ... and more specific bibliography associated with each class



Bibliography (2)

- **ISO/IEC 27000:2015** Information technology — Security techniques — Information security management systems — Overview and vocabulary
- **ISO/IEC 27001:2013** Information technology - Security techniques -- Information security management systems – Requirements
- **ISO/IEC 27007:2017** Information technology — Security techniques — Guidelines for information security management systems auditing
- **The ISO27k Toolkit:** <http://www.iso27001security.com>



Logistics

- Course webpage
 - AS @ NONIO and UCTeacher
- Online classes
 - <https://dei.uc.pt/vc/msi>
- Teacher's info
 - Emails: naseixas@dei.uc.pt, psimoes@dei.uc.pt
 - Slack: <https://join.slack.com/t/dei-as-2026/signup>
 - Office D3.5 (Nuno Seixas), D3.16 (Paulo Simões)